

Final Review 3 Discussion Document

Project

Nivara Partners Donor Operations Portal

Purpose

This document contains the conceptual and review-facing cybersecurity discussion for the final evaluation. The application itself is kept focused on production-style workflows: authentication, donation entry, donor ledger, operations dashboard, and audit monitoring.

System Integration and Hardening

- The portal integrates identity, role-based access, donation record management, audit events, and administrative monitoring.
- Users authenticate before accessing protected workflows.
- Donors can view and record their own contributions.
- Administrators can review donation records and audit events.
- Server-side validation, CSRF checks, signed sessions, and parameterized queries reduce common web risks.
- Security response headers reduce browser-side attack surface.
- Failed login tracking provides basic brute-force resistance.

Implemented Controls

Area	Evidence	Status
Authentication	PBKDF2 password hashing, signed sessions, session expiry	Implemented
Authorization	Donor/admin RBAC on dashboard and API routes	Implemented
Input Validation	Strict validation for email, name, amount, and purpose	Implemented
Injection Defense	Parameterized SQLite queries	Implemented
CSRF Defense	Session-bound CSRF tokens on state-changing requests	Implemented
Monitoring	Audit events for login, logout, blocked access, CSRF, and donations	Implemented
Brute-force Control	Failed login throttling	Implemented
Browser Hardening	CSP, frame denial, no-sniff, referrer policy, permission policy, no-store	Implemented

Risk Assessment After Mitigation

Threat	Initial Risk	Mitigation	Residual Risk
SQL Injection	High	Parameterized queries and input validation	Low
Broken Access Control	High	RBAC checks on dashboard and API routes	Low
CSRF	Medium	CSRF token validation	Low
Brute-force Login	Medium	Sliding-window failed login throttling	Medium
Session Theft	High	HttpOnly SameSite cookies; HTTPS Secure flag in deployment	Medium
Sensitive Data Exposure	High	Least-privilege views and no-store headers	Medium

OWASP and NIST Mapping

- OWASP A01 Broken Access Control: donor/admin role checks protect dashboard and API access.
- OWASP A03 Injection: parameterized database operations prevent SQL injection payload execution.
- OWASP A07 Identification and Authentication Failures: password hashing, signed sessions, expiry, and rate limiting reduce authentication risk.
- OWASP A09 Security Logging and Monitoring Failures: audit events provide investigation evidence.
- NIST Cybersecurity Framework:
 - Identify: risks are documented through threat and risk assessment.
 - Protect: validation, RBAC, sessions, and CSRF defenses protect workflows.
 - Detect: audit events and failed-login metrics support detection.
 - Respond: administrators can review events and investigate suspicious behavior.
 - Recover: production version should include encrypted backups and recovery procedures.

Cloud Security Architecture

Recommended cloud design:

User -> DNS/CDN/WAF -> HTTPS Load Balancer -> Private Application Service -> Private Database

Supporting services:

- IAM with least privilege and MFA for administrators.
- Secret Manager for application secrets and database credentials.
- KMS for encryption keys.
- Cloud monitoring or SIEM for logs and alerts.
- Encrypted backups with retention policies.

- Network security groups allowing only required inbound traffic.

Cloud security risks:

- Publicly exposed database.
- Weak IAM permissions.
- Leaked access keys.
- Misconfigured storage.
- Missing log monitoring.
- Unencrypted backups.

AI/ML in Cybersecurity

AI/ML can improve cybersecurity conceptually by:

- Learning normal login and access patterns.
- Detecting abnormal request spikes or repeated failed attempts.
- Scoring suspicious donation behavior using amount, frequency, IP reputation, and account history.
- Prioritizing audit events for administrators.
- Supporting anomaly detection in cloud monitoring logs.

AI/ML should support analysts and administrators. It does not replace secure coding, authentication, access control, patching, or monitoring.

Final Presentation Slide Content

Use `docs/review3\_ppt\_contents.md` for slide-by-slide content.